Agency → Client Deploy Handoff

The agency → client deploy handoff runs as an **interactive key rotation**: the human executes, the agent prepares, verifies, and records — secrets never enter the transcript.

Checklist + Interactive Key Rotation ceremony. This document is the normative handoff procedure for transferring a deployed CRM Sync / headless commerce stack from the implementing agency to the client organization's own infrastructure (their GitHub, their Cloudflare, their Shopify/Xano accounts). It exists so that **security custody is provable**: every credential is re-minted (never copied), every rotation is performed by a named human with an agent verifying and documenting, and the resulting audit trail is usable as evidence for Legal/Compliance (PII processor documentation) and for recurring Security-Scaling reports.

> Referenced from Functional Spec §13. Roles below map to the spec's Document Control roles (DPO, Engineering Lead) plus the handoff-specific **Security Human** and **Agent**.

0. Roles

ROLE	WHO	DOES	NEVER DOES
Agency Operator	implementing agency engineer	runs the stack pre-handoff; prepares inventory; revokes own access at the end	retains any working credential past Phase E
Security Human	client-side named individual (recorded in the audit log)	**executes** every mint/rotation interactively (dashboard or CLI); approves scope	delegates execution to automation
Agent	AI/automation operator (e.g. Claude Code session, CI)	prepares runbooks, pre-checks, **verifies** old-dead/new-alive, writes the audit record	mints, holds, or transports production credentials
DPO / Compliance	client	receives the PII map + audit trail; signs §6	—

The **Interactive** in Interactive Key Rotation is a policy, not a mood: agents prepare and verify, humans execute. Credential creation is a human act with a named owner, which is what makes the audit trail meaningful to a regulator.

A. Pre-handoff inventory (Agency Operator + Agent)

☐ Enumerate every credential in the live stack into the **Credential Inventory table** (template in §1 below): name, system, scope, storage location (worker secret / CI secret / KV / local key file), fingerprint (first 8 hex of SHA-256 of the secret — never the secret), mint date.

☐ Enumerate infrastructure objects: GitHub repos + Actions secrets/vars, Cloudflare Workers (+ secrets, KV namespaces, R2 buckets, Vectorize indexes,

crons), Pages projects (+ preview branches), Shopify app(s) + granted scopes, Xano workspace + API key scopes, Webflow site tokens, DNS zones.

- ☐ Snapshot configuration that is NOT secret (wrangler.toml, workflow files, scope lists) into the handoff package.
- ☐ Produce the **PII map** (§6) and the current **tenant token census** (issued `crm_t_*` tokens, their tenants, last-used).
- ☐ Tag the repo state being handed over (e.g. `handoff-YYYY-MM-DD`).

B. Infrastructure transfer (Client + Agency)

- ☐ GitHub: transfer repo(s) to the client org (or fork + archive agency copy). Re-create Actions **secrets** in the client org — secrets do not survive transfer and must not: they get **new values** in Phase C.
- ☐ Cloudflare: create client-account Workers + Pages projects; move DNS. (Direct-upload Pages projects are re-created, not transferred; deploy from the client's CI on first run.)
- ☐ Shopify: client creates **their own app** (own client_id/secret) with the documented scope list; agency app is uninstalled in Phase E.
- ☐ Xano: workspace ownership to client billing; agency seats reduced to read-only until Phase E, then removed.
- ☐ Verify the stack runs end-to-end on client infrastructure using **temporary handoff credentials** before key rotation begins.

C. Secret re-mint — the core rule: **nothing is copied, everything is replaced**

Execute as an **Interactive Key Rotation ceremony** (§D) per credential class, in dependency order (consumers after producers):

- [ ] 1. **Cloudflare API token** (CI deploy) — minted by Security Human in the client Cloudflare dashboard; scoped to the specific account + Workers/Pages edit only.
- [ ] 2. **GitHub dispatch token** — fine-grained PAT, **single repo**, Contents read/write only (never an account-wide OAuth token).
- [ ] 3. **Worker shared secrets** (`EXPORT_TOKEN`, webhook HMAC secrets, `ECHO_SECRET`) — generated fresh (`openssl rand -hex 32`), set as worker secrets + CI secrets in the same sitting.
- [ ] 4. **Platform** `ADMIN_KEY` — new root key; then mint the rotatable key via `POST /admin/rotate-key` so day-2 rotation never touches root.
- [ ] 5. **Tenant tokens** (`crm_t_*`) — re-issue per tenant; old tokens revoked; census updated.
- [ ] 6. **Xano API keys** — master metadata key replaced; scoped `entitlement:read` key minted separately (read path never holds the master key).

7. **Shopify** — client app's secret in worker config; first client-credentials token mint verified; old app's tokens die with its uninstall.

☐

8. **Webflow site tokens** — re-minted per site/market (site-scoped).

☐

9. **Entitlement signing keys** — `POST /entitlement/signing-keys/rotate` (`next → active → retired`, non-destructive overlap).

☐ After each: **Agent verifies** old credential returns 401/dead, new credential serves 200/alive, and writes the audit record (§D format).

D. Interactive Key Rotation — the ceremony

One sitting per credential class. **Human executes, Agent verifies, both are recorded.**

1. **Schedule** — Security Human + Agent session; change window noted.
2. **Prepare** (Agent) — runbook for the specific credential: where it lives, every consumer that must be updated, the verification probes, the rollback (overlap window where old + new are both valid, when the system supports it — admin keys and signing keys do; bearer tokens get a short dual-accept window or a maintenance moment).
3. **Execute** (Security Human) — mints in the provider dashboard or runs the CLI command themselves. Agents may display the command; the human runs it.
4. **Verify** (Agent) — probes: new key authenticates on every consumer surface; old key is rejected everywhere; no service interruption signals.
5. **Record** (both) — append one audit entry:

```
date: 2026-06-12T18:40Z
credential: ADMIN_KEY (rotatable tier)
action: rotate            # mint | rotate | revoke
executed_by: <Security Human name>        # the human, always
verified_by: <Agent session/run id>
reason: scheduled-90d     # handoff | scheduled-90d | personnel | incident | scope-change
old_fingerprint: 3fa1b2c4 # sha256[:8] — never the secret
new_fingerprint: 9d77e012
overlap_window: 24h       # or "none"
consumers_updated: worker secret, CI secret
```

- ☐ Audit log lives in the client's compliance store (not in a public repo); fingerprints only, never secret material.
- ☐ **Rotation triggers** (any of): handoff (this document), **90-day cadence**, personnel change with credential exposure, suspected incident, scope change on the credential.

E. Agency access revocation (the handoff moment)

- ☐ Agency delegate/admin keys revoked — and **verified dead** by probe.
- ☐ Agency GitHub/Cloudflare/Xano/Webflow/Shopify seats removed.
- ☐ Agency local key files destroyed (attested in the audit log).
- ☐ Final entry in the audit log: `action: revoke, reason: handoff` for every agency-held credential. **Handoff is complete when the inventory table shows zero agency-fingerprinted credentials alive.**

F. Legal / Compliance-PII package (DPO receives)

- ☐ **PII map**: which systems hold personal data (identity store, commerce customers, consent records, analytics user properties — hashed where applicable), with table/object names and retention notes.
- ☐ **Processor chain**: edge/compute, data layer, commerce, analytics, email — for the DPA annex.
- ☐ **Subject-rights rails**: data_request / redact webhook handlers and their verification (HMAC), consent versioning (Consent Mode v2, version-monotonic consent guard) — documented as implemented controls.
- ☐ **Access matrix post-handoff**: who (human or agent) can read/write PII per system. Agents appear here explicitly with their *verifier* role.
- ☐ **Rotation audit trail** (§D records) attached as evidence that credential custody transferred on a named date by named individuals — this is the artifact that makes the handoff defensible.

G. Security-Scaling Report (recurring, quarterly or per-market launch)

- ☐ Credential inventory diff: keys added/rotated/revoked since last report; **age of every live credential** (flag > 90 days).
- ☐ Rotation ceremonies performed (count, mean credential age at rotation, any skipped cadences + why).
- ☐ Tenant token census: issued / active / revoked `crm_t_*`; orphans.
- ☐ Auth anomaly summary: 401 spikes per surface, fail-closed verification (no fail-open paths in admin auth).

- [ ] Consent integrity: state_version monotonicity spot-check across channels; signals eligibility vs. consent state; consent allow/deny tally.
- [ ] **Cross-channel data scope (appendix):** the Data-Scope Matrix — every outbound flow by data class, destination, consent class — with the egress audit sweep result (an undeclared external write fails it).
- [ ] **Channel cursor lag:** per-channel how-far-behind-the-bus, so a stalled or never-synced projection is visible at a glance.
- [ ] Scaling thresholds: tenants/markets added; when crossing tier boundaries (shared → private → enterprise), re-run §C for the new isolation boundary.
- [ ] Report is signed by the Security Human and filed with the DPO package.

> The matrix appendix, channel cursor lag, and consent tally are emitted live by the platform's governance report so this section assembles from real data, not by hand.

---

1. Credential Inventory table (template)

#	CREDENTIAL	SYSTEM	SCOPE	STORED IN	FINGERPRINT	MINTED	OWNER
1	ADMIN_KEY (root)	worker	platform admin	CF secret	`________`	____	Securi Huma
2	ADMIN_KEY (rotatable)	worker	admin surfaces	CF secret + KV meta	`________`	____	Securi Huma
3	EXPORT_TOKEN	worker + CI	build data feed	CF secret + GH secret	`________`	____	Securi Huma
4	GitHub PAT (dispatch)	worker	1 repo, contents	CF secret	`________`	____	Securi Huma
5	Cloudflare API token	CI	Workers/Pages edit	GH secret	`________`	____	Securi Huma
6	Xano master meta key	worker	workspace metadata	CF secret	`________`	____	Securi Huma
7	Xano entitlement:read	worker	read-only	CF secret	`________`	____	Securi Huma
8	Shopify app secret	worker	client-credentials grant	CF secret	`________`	____	Securi Huma
9	Webflow site token(s)	worker	per-site CMS	CF secret / KV	`________`	____	Securi Huma
10	Tenant tokens `crm_t_*`	KV	per-tenant	KV (revocable)	per-tenant	____	tenant admin
11	Entitlement signing keys	Xano (192)	token signing	next→active→retired	key version	____	Securi Huma

Add rows for market-specific tokens as markets launch; the table is the living object the quarterly report (§G) diffs against.